

OSINT

Cassiano Peres

DIO Tech Education Analyst

 cassiano-dio

 peres-cassiano

Objetivo Geral

Nesta aula vamos falar sobre OSINT, ou inteligência de fontes abertas e como obter dados sobre alvos.

Pré-requisitos

Este curso requer algum conhecimento de programação básica.

Percurso

Etapa 1

O que é OSINT?

Etapa 2

Pensamento OSINT

Etapa 3

Google Hacking

Percurso

Etapa 4

Conhecendo o Shodan

Etapa 5

Maltego

Etapa 6

FOCA

Etapa 1

O que é OSINT?

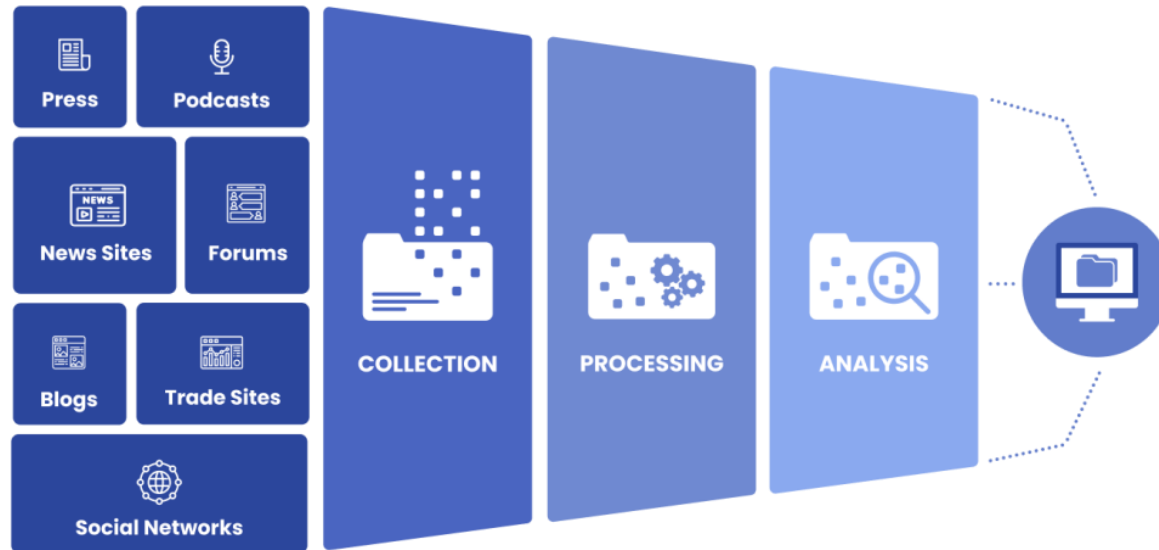
Introdução

Nesta aula vamos conhecer o framework OSINT, a inteligência de fontes abertas.

OSINT

OSINT significa *Open Source Intelligence*, ou inteligência de fontes abertas, ou seja, informações abertas na internet ao público.

OSINT

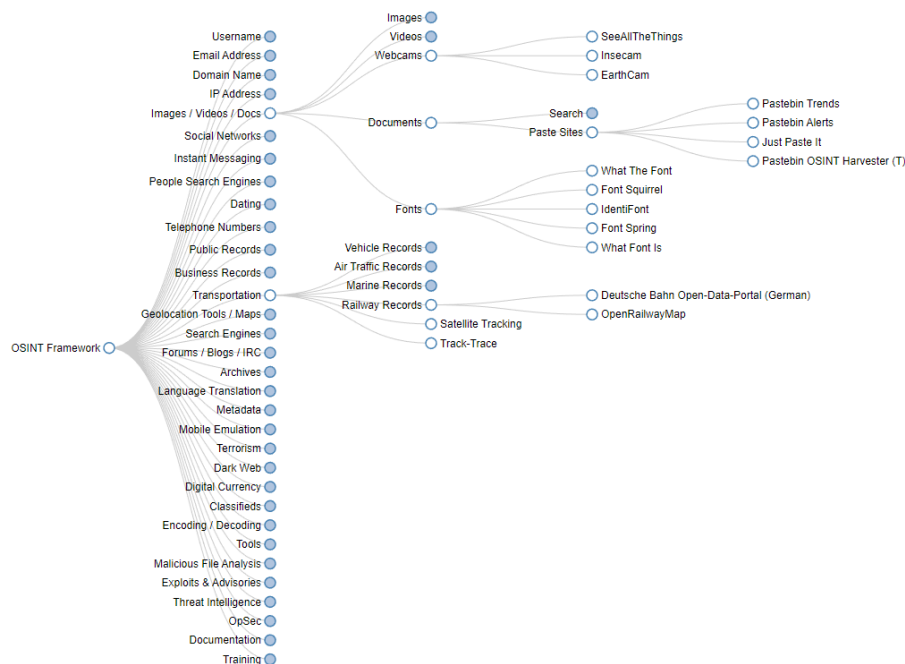


OSINT

<https://osintframework.com/>

OSINT Framework

(T) - Indicates a link to a tool that must be installed and run locally
(D) - Google Dork, for more information: [Google Hacking](#)
(R) - Requires registration
(M) - Indicates a URL that contains the search term and the URL itself must be edited manually



OSINT

Para o OSINT são utilizadas ferramentas voltadas para:

- Coleta de informações;
- Mapeamento e enumeração de serviços;
- Análise de vulnerabilidades;
- Análise de arquivos;
- Extração de metadados.

Tipos de fontes

- Blogs;
- Fóruns,
- Mídias sociais;
- Mídias tradicionais;
- Registros governamentais;
- Etc.

Uso de OSINT

USE CASES OF OSINT INVESTIGATIONS



Network
Footprint



Person
of Interest



Cryptocurrency
Activities



Malware
& Threats



Phishing
& Fraud

Uso de OSINT

- Legislações;
- Combate a frauds;
- Recursos humanos;
- Cibersegurança;
- Operações militares.

Importância do OSINT

- Identificar violações de dados;
- Due Diligence do Cliente (CDD);
- Descobrir vulnerabilidades;
- Apoio aos processos de tomada de decisão;
- Atualizações.

Benefícios do OSINT

- Camada extra de segurança;
- Economia nos processos de decisão;
- Dados analisados conforme são atualizados.

Contratempos do OSINT

- Dificuldade de filtrar os dados inúteis;
- Sem ferramentas o trabalho é moroso;
- Alta necessidade de comandos humanos;
- Não há um padrão ideal definido sobre a quantidade de informações coletadas e analisadas.

Técnicas do OSINT

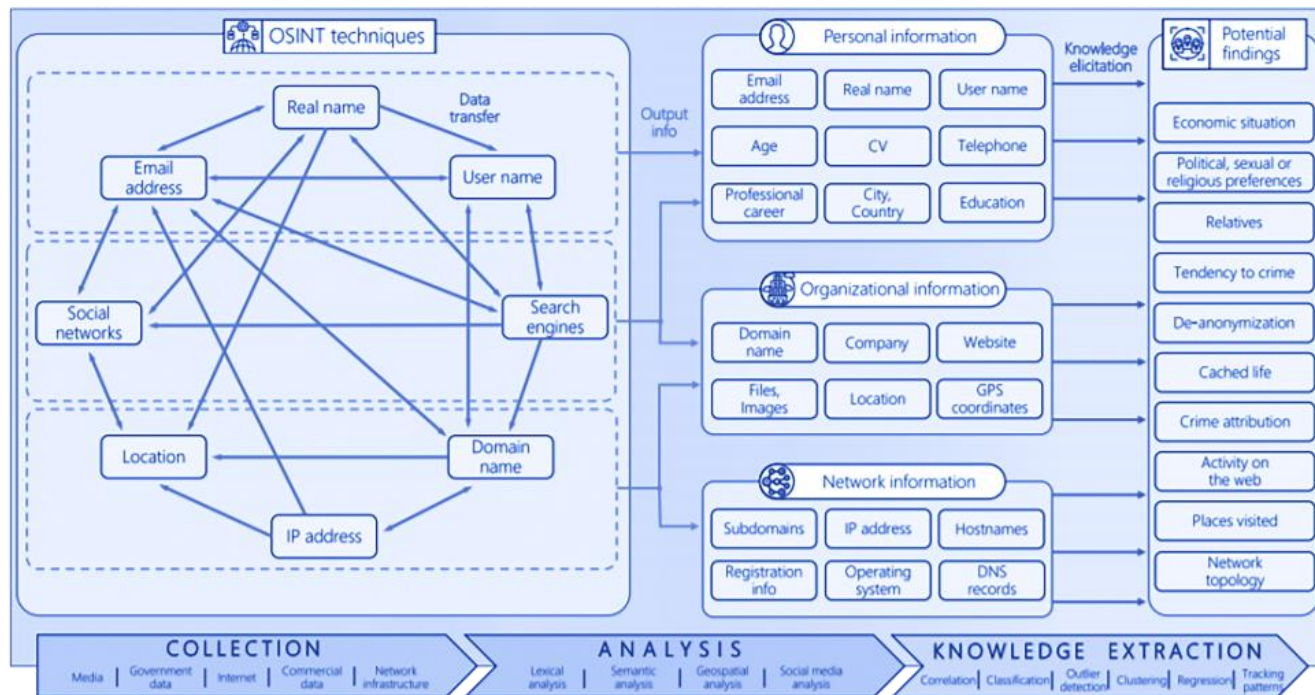
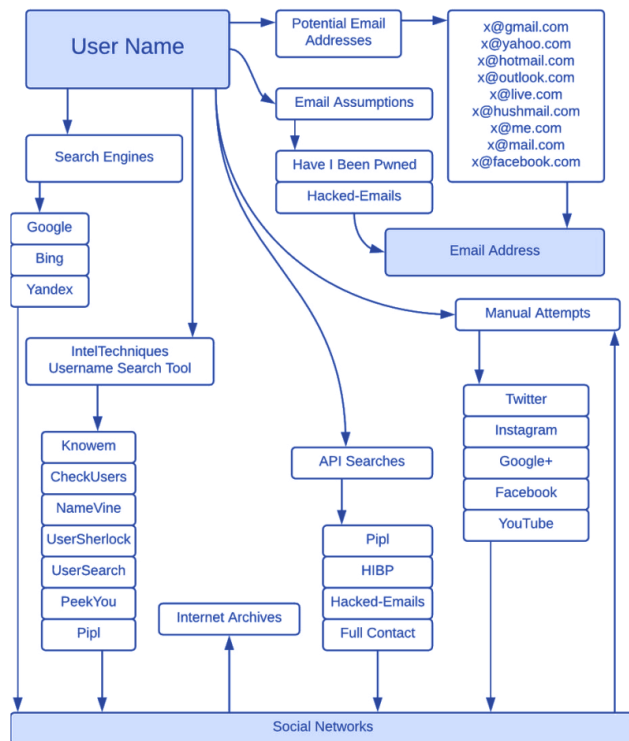


FIGURE 2. Principal OSINT workflows and derived intelligence.

Técnicas do OSINT



Conclusão

OSINT pode ser considerado um canivete suíço do pentester, sendo extremamente útil para preparar a defesa contra ataques maliciosos.

Etapa 2

Pensamento OSINT

Introdução

Além de ter em mãos as fontes e ferramentas para análise de dados, precisamos saber como utilizá-los da forma mais efetiva possível

Mindset OSINT

OSINT requer uma mentalidade especial, incluindo habilidades analíticas, flexibilidade de pensamento e paciência.



Mindset OSINT

- Quais as fontes escolhidas?
- Qual a confiabilidade das fontes?
- Quais palavras chaves utilizar?
- Quais as melhores ferramentas?

Mindset OSINT

Não adianta ter as melhores fontes e ferramentas se não souber como utilizá-las.

Mindset OSINT

OFFENSIVE

Makes direct contact with the target.



- ▶ **Real-time** / more accurate data
- ▶ **Higher Risk** of being detected by target

1

PASSIVE

Does not make direct contact with the target.



- ▶ **Historical** 3rd-party records
- ▶ **Low Risk** of being detected

2

Mindset OSINT

- Escolher o assunto pesquisado;
- Definição de fontes;
- Reunir palavras-chave;
- Escolher a ferramenta OSINT;
- Refinar as informações contradas;
- Cuidado com informações falsas.

Etapa 3

Google Hacking

Introdução

Nesta aula vamos falar sobre o uso de técnicas de pesquisas avançadas utilizadas no Google para encontrar informações.



Introdução

O Google Hacking nada mais é que uma prática para encontrar arquivos e/ou falhas a partir do Google, usando ele como uma espécie de scanner, com comandos de buscas avançadas por strings chamadas de “**dorks**” ou “**operadores de pesquisa**”.

Dorks

Com a composição de dorks podemos retornar domínios específicos, títulos, palavras, arquivos, etc.

Dorks

- “**site:**” Busca em um site específico:

site:exemplo.com.br

- “**intitle:**” Busca por título de páginas:

intitle:"< Fazer login"

- “**inurl:**” Busca de termos presentes na url:

inurl:/wp-admin

Dorks

- “**intext:**” Busca por texto no conteúdo do site:

intext:adminpass

- “**filetype:**” Busca por formato de arquivos (.jpg,.zip,.txt):

filetype:.txt

- “**inurl:**” Busca de termos presentes na url:

inurl:/wp-admin

Dorks

- “**-termo**”: O sinal de “-” exclui um termo da pesquisa
- “**2021...2022:**” Busca entre datas

Bancos de dados de Dorks

São sites com várias Dorks voltadas à exploração de vulnerabilidades em sites.

- Exploit-db

<https://www.exploit-db.com/google-hacking-database>

- InurlBR

Construindo Dorks

Vamos explorar algumas Dorks e obter informações com o Google Hacking.

Conclusão

Nesta aula tivemos uma noção do quão abertos são os sistemas e o perigo que isso representa.

Etapa 4

Conhecendo o Shodan

Introdução

Nesta aula vamos conhecer o Shodan, o “Google dos Hackers”, utilizado para encontrar dispositivos conectados à internet.



Shodan

- Lançado em 2009, é um mecanismo de busca desenvolvido pelo programador John Matherly;
- Acessado por meio de um endereço na web, busca diversos tipos de dispositivos conectados à internet;
- Esses dispositivos podem ser desde computadores, servidores, mobile até câmeras abertas.

Shodan

<https://www.shodan.io/>

The screenshot displays the Shodan search engine interface. At the top, there is a navigation bar with links for Shodan, Developers, Monitor, and View All. A search bar contains the query 'itaperuna'. To the right of the search bar are links for Explore, Pricing, and Enterprise Access. Further right are links for 'Try out the new beta website!' and 'Help Center'. Below the search bar, there are links for 'New to Shodan?' and 'Login or Register'.

On the left side, there are tabs for 'Exploits' and 'Maps'. Below these, the 'TOTAL RESULTS' section shows '4'. The 'TOP COUNTRIES' section shows a world map with Brazil highlighted in red. Below the map, the 'TOP SERVICES' section lists 'PPTP' and 'Automated Tank Gauge'. The 'TOP ORGANIZATIONS' section lists 'Itanet Conecta Ltda'.

The main content area displays search results. A banner at the top reads 'New Service: Keep track of what you have connected to the Internet. Check out Shodan Monitor'. Below this, there are three search results. Each result shows a location (Brazil, Itaperuna) and a list of services. The first result shows 'Firmware: 1', 'Hostname: NossaLoja15-Itaperuna', and 'Vendor: Mikrotik'. The second result shows 'I20100', '18/03/21 15:29', 'Auto Posto Marco', 'BR 356 S/N KM 03', and 'Itaperuna'. The third result shows 'Firmware: 1', 'Hostname: FORTE-CPE-IFF-ITAPERUNA', and 'Vendor: Mikrotik'.

Below the search results, there is a table titled 'INVENTÁRIO NO TANQUE' (Inventory in the Tank). The table has columns for 'TANQ PRODUTO', 'VOLUME TC-VOLUME', 'VOLUME', 'ALTURA', 'ÁGUA', and 'TEMPER'. The data rows are:

TANQ PRODUTO	VOLUME TC-VOLUME	VOLUME	ALTURA	ÁGUA	TEMPER
1 Gasolina Comun	9596	0	10644	1222.67	0.00 30.18
2 Gasolina GRID	6223...				

Shodan

Permite listar e filtrar dispositivos por localização, tipo de servidor, portas.

Shodan

Search Query Examples

[FILTER REFERENCE](#)

// BASICS

Websites that require HTTPS connections

`HTTP Strict-Transport-Security`

SEARCH

Services that have the word "Apache" in their headings

`Apache`

SEARCH

Apache web servers

`product:Apache`

SEARCH

Services with a hostname containing either "google.com"
OR "facebook.com"

`hostname:google.com,facebook.com`

SEARCH

// HTTP FILTERS

Websites that have the word "Apache" in their HTML

`http.html:Apache`

SEARCH

Websites that are using the Bootstrap CSS framework

`http.component:bootstrap`

SEARCH

Prática

Vamos praticar alguns comandos de filtros e listagens no Shodan.

Etapa 5

Maltego

Introdução

Nesta aula vamos falar de outra ferramenta de OSINT, o Maltego.



MALTEGO

Maltego

É um dos frameworks OSINT mais famosos para reconhecimento **pessoal e organizacional**.

Maltego

É uma ferramenta GUI que permite coletar informações sobre **qualquer indivíduo**, extraíndo as informações que estão **publicamente disponíveis na internet** por diferentes métodos.

Maltego

1



Mapping the
online footprint
of the person of
interest

2



Finding
personal detail
from known
online presence

3



Using identity
intelligence to
understand the
target's profile

Maltego

Maltego Kali Linux Edition 3.6.1

Investigate Manage View Organize Machines Collaboration

Clipboard Transforms Find Selection Zoom

Palette

- Devices
- Infrastructure
- Locations
- Malware
- Penetration Testing
- Personal
- Social Network

Run View

Transforms

- All Transforms
- DNS from Domain
- DomainToDNSNameSchema
- DomainToDNSZoneTransfer
- To DNS Name - interesting - [...]
- To DNS Name - MX (mail serv...)
- To DNS Name - NS (name se...)
- To DNS Name - Find common ...
- To DNS Name [using DB]
- To Website [Quick lookup]

Overview

Detail View

Domain: maltego Domain: nist.gov

Relationships

- Outgoing
- av.nist.gov
- admin.nist.gov
- domino.nist.gov
- edge.nist.gov
- help.nist.gov
- imap.nist.gov
- www.nist.gov
- ftp.nist.gov
- apache.nist.gov
- debian.nist.gov
- edge.nist.gov
- imap.nist.gov
- www.nist.gov

Property View

Properties

Type	Domain
Domain Name	nist.gov
WHOIS Info	
Graph info	
Weight	0
Incoming	0
Outgoing	12
Bookmark	★

Output - Transform Output

```

TransformToLocation returned with 1 entities (from entity "129.6.72.37")
TransformToLocation returned with 1 entities (from entity "129.6.162.162")
TransformToLocation returned with 1 entities (from entity "216.58.195.51")
TransformToLocation returned with 1 entities (from entity "132.163.4.162")
TransformToLocation returned with 1 entities (from entity "129.6.13.25")
TransformToLocation returned with 1 entities (from entity "129.6.83.179")
TransformToLocation returned with 1 entities (from entity "129.6.61.155")
TransformToLocation returned with 1 entities (from entity "129.6.93.201")
TransformToLocation returned with 1 entities (from entity "129.6.24.35")
TransformToLocation returned with 1 entities (from entity "129.6.72.37")
TransformToLocation returned with 1 entities (from entity "129.6.162.162")
TransformToLocation returned with 1 entities (from entity "129.6.16.94")
TransformToLocation returned with 1 entities (from entity "129.6.61.155")
TransformToLocation returned with 1 entities (from entity "129.6.93.201")
TransformToLocation done (from 10 entities)
  
```

1 of 26 entities

Maltego

Possui versões pagas e *community*, gratuita para uso mas com funcionalidades a menos.

O que o Maltego encontra?

- Pessoas
- Grupos de pessoas (redes sociais)
- Empresas
- Organizações
- Sites

O que o Maltego encontra?

- Domínios
- Nomes DNS
- Blocos de rede
- Endereços IP
- Afiliações
- Documentos e arquivos

Benefícios do Maltego

O Maltego pode ser útil para a fase de coleta de informações de todos os trabalhos relacionados à segurança, gerando economia de tempo, adicionando mais precisão e inteligência.

Prática

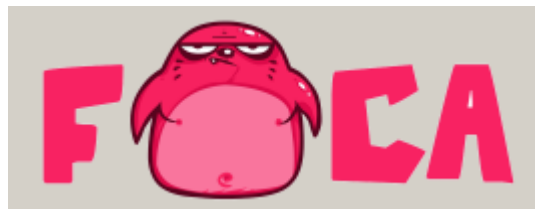
Vamos instalar e fazer algumas pesquisas com o Maltego.

Etapa 6

FOCA

Introdução

Nesta aula vamos falar de outra ferramenta de OSINT, o FOCA.



FOCA

FOCA significa *Fingerprinting & Organisation with Collected Archives*, sendo uma ferramenta utilizada para encontrar, fazer download, analisar e extrair metadados de arquivos.

FOCA

Podem ser arquivos como MS Office, PDF, Open Office, SVG e uma infinidade de formatos.

<https://github.com/ElevenPaths/FOCA/releases>



FOCA

Permite encontrar metadados como:

- Usuários do software;
- Versão do software;
- Pastas;
- Sistemas operacionais;
- Etc.

FOCA

Vamos instalar o foca e analisar alguns arquivos para extração de metadados.

Dúvidas?

- > Fórum/Artigos
- > Comunidade Online (Discord)

